

Penetration Testing Report

Exploitation & System Security – Task 4

1. Introduction

This report documents the practical activities completed as part of the Exploitation & System Security task. All exercises were performed in a controlled lab environment for educational purposes.

2. Objective

- Understand the penetration testing workflow.
- Perform ethical exploitation on a vulnerable machine.
- Conduct password attacks.
- Demonstrate social engineering awareness.
- Perform basic web application testing.
- Learn basic malware analysis.
- Apply system hardening practices.

3. Lab Environment

Component	Details
Attacker Machine	Kali Linux
Target Machine	Metasploitable2
Web Server	Python HTTP Server
Tools Used	Metasploit, Hydra, John the Ripper, Nikto, Firefox

4. Penetration Testing Methodology

Reconnaissance: Target identified and prepared for testing. [Insert Screenshot]

Scanning: Services identified before exploitation. [Insert Screenshot]

Exploitation: A known vulnerability was exploited using Metasploit. Meterpreter session established. Commands executed: sysinfo and hashdump. [Insert Screenshot]

Post-Exploitation: System information and password hashes were collected. [Insert Screenshot]

5. Password Attacks

Hydra: Performed a dictionary attack against the FTP service using custom username and password lists. Valid credentials recovered: Username = msfadmin, Password = msfadmin. [Insert Screenshot]

John the Ripper: Password hashes were analyzed using the default wordlist and RockYou wordlist. Although no password was recovered, the exercise demonstrated offline password auditing. [Insert Screenshot]

6. Social Engineering (Simulation)

Created an HTML phishing awareness page containing username and password fields and an educational warning. No real credentials were collected. [Insert Screenshot]

7. Web Application Testing

Hosted a demo login page locally using Python HTTP Server and scanned it using Nikto. Findings included missing security headers, outdated HTTP server version, directory listing enabled, and login page detection. [Insert Screenshot]

8. Malware Basics

Created a benign sample file and performed static analysis using the 'file' and 'strings' commands without executing the file. [Insert Screenshot]

9. System Hardening

Updated package information using apt update, checked firewall status with ufw status, and reviewed enabled services using systemctl list-unit-files --state=enabled. [Insert Screenshot]

10. Findings

Finding	Severity
Weak FTP credentials identified	High
Password auditing performed	Medium
Missing HTTP security headers	Medium
Directory listing enabled	Medium
Outdated HTTP server	Low
Basic phishing awareness page created	Informational
Static malware analysis completed	Informational
System services reviewed	Informational

11. Mitigation Recommendations

- Use strong and unique passwords.
- Replace FTP with SFTP where possible.
- Keep web servers updated.
- Add recommended HTTP security headers.
- Disable unnecessary directory listing.
- Provide phishing awareness training.
- Analyze suspicious files in isolated environments.
- Regularly update the operating system.
- Disable unused services.
- Enable and configure the firewall.

12. Conclusion

This task provided practical experience with the penetration testing workflow, including exploitation, password attacks, web application testing, social engineering awareness, malware analysis, and system hardening. All activities were performed in a controlled environment for educational purposes.